

Name: Preet Patel

Module 4 CS- Securing Web Applications Services & Servers

1. Explain MAC spoofing and Email spoofing.

Ans: MAC Spoofing:

MAC Spoofing is a technique where a user changes the MAC (Media Access Control) address of a network device to impersonate another device. Attackers use it to bypass network restrictions, hide their identity, or gain unauthorized access to a network. Since MAC addresses are used to identify devices, spoofing can make a device appear legitimate. It is often used in cyberattacks and network security testing.

Email Spoofing:

Email Spoofing is the practice of sending emails with a forged sender address to make the message appear as if it came from a trusted source. Attackers use it for phishing, fraud, and spreading malware. The recipient may believe the email is genuine and reveal sensitive information. Email authentication methods such as SPF, DKIM, and DMARC help reduce email spoofing attacks.

2. Perform practical of MITM tool and social engineering Tool.

Ans: MITM (Man-in-the-Middle) Tool – Practical Overview:

A MITM tool is used in cybersecurity labs to demonstrate how communication between two devices can be intercepted. During a controlled security test, the tool monitors network traffic to identify vulnerabilities. Security professionals use it only with proper authorization. The practical helps students understand the importance of encryption and secure communication. Unauthorized use of MITM tools is illegal and unethical.

Social Engineering Tool – Practical Overview:

A social engineering tool is used in security awareness training to show how attackers may trick users into revealing information. In a controlled environment, it can simulate phishing emails or fake login pages for educational purposes. The goal is to teach users how to recognize suspicious requests and avoid scams. Such tools should only be used with permission and for training or testing. Ethical use helps improve organizational security awareness.

3. Explain Kali linux tool SYN Flooding Attack using Metasploit.

Ans: SYN Flooding Attack using Metasploit (Kali Linux):

A SYN Flooding attack is a type of Denial-of-Service (DoS) attack that overwhelms a server with a large number of TCP connection requests (SYN packets). In cybersecurity labs, tools available in Kali Linux and frameworks like Metasploit Framework can be used to demonstrate how such attacks affect network services. The server allocates resources for each request but never receives the final acknowledgment, causing resource exhaustion. This practical helps students understand network vulnerabilities and the importance of security controls. Protection methods include firewalls, SYN cookies, rate limiting, and intrusion detection systems.

4. Find online email encryption service.

Ans: Online Email Encryption Service:

An online email encryption service protects email messages by converting them into a secure format that only authorized recipients can read. Popular services include [Proton Mail](#), [Tuta Mail](#), and [Virtru](#). These services use strong encryption methods to keep emails private and secure. They help protect sensitive information from hackers and unauthorized access. Email encryption is widely used by businesses and individuals to ensure secure communication over the internet.

5. Types of Firewall.

Ans: Types of Firewall:

A firewall is a security system that monitors and controls network traffic based on security rules. The main types are Packet Filtering Firewall, which checks packets based on IP addresses and ports; Stateful Inspection Firewall, which tracks active connections; Proxy Firewall, which acts as an intermediary between users and the internet; Application Firewall, which filters traffic at the application level; and Next-Generation Firewall (NGFW), which provides advanced features such as intrusion prevention and deep packet inspection. Firewalls help protect networks from unauthorized access and cyber threats.

6. Explain Evading Firewalls.

Ans: Evading Firewalls:

Evading firewalls refers to techniques attackers may use to bypass or avoid firewall security controls. These methods can include disguising malicious traffic to appear as normal network traffic or exploiting misconfigured firewall rules. Understanding firewall evasion helps security professionals identify weaknesses and improve network protection. Organizations use advanced firewalls, intrusion detection systems, and regular security updates to defend against such attempts. Learning about firewall evasion is important for cybersecurity awareness and defensive security practices.

● Web Based Hacking

1. What is Session Hijacking Explain with Techniques?

Ans: Session Hijacking:

Session Hijacking is a cyberattack in which an attacker takes control of a user's active session with a website or application. The attacker gains access by obtaining or stealing the session ID used to identify the logged-in user. Common techniques include Session ID theft, Cross-Site Scripting (XSS) attacks, Man-in-the-Middle (MITM) attacks, and Session Fixation. Once the session is hijacked, the attacker can access the user's account without knowing the password. Secure cookies, HTTPS, and session timeouts help prevent session hijacking.

2. Find DoS/DDoS Attack Tools.

Ans: DoS/DDoS Attack Tools:

DoS (Denial of Service) and DDoS (Distributed Denial of Service) attack tools are commonly studied in cybersecurity to understand network threats and test defenses in authorized environments. Examples include LOIC, HOIC, Slowloris, and hping3. These tools can generate large amounts of network traffic to evaluate system resilience. Security professionals use them only in controlled and authorized testing environments. Unauthorized use against networks or services is illegal and unethical.

3. Explain SYN Flooding Attack with example.

Ans: SYN Flooding Attack:

A SYN Flooding attack is a type of Denial-of-Service (DoS) attack that exploits the TCP three-way handshake process. The attacker sends a large number of SYN (connection request) packets to a server but does not complete the connection. The server keeps waiting for responses and allocates resources for each request. As these requests accumulate, the server's resources become exhausted, making it unable to serve legitimate users. For example, a website may become slow or unavailable when flooded with thousands of fake connection requests.

4. List of Web App Hacking Methodology.

Ans: Web Application Hacking Methodology:

Web application security testing follows a structured methodology to identify vulnerabilities. The main steps include Information Gathering (collecting details about the target application), Scanning and Enumeration (finding open services and entry points), Vulnerability Assessment (identifying security weaknesses), Exploitation Testing (verifying vulnerabilities in an authorized environment), and Reporting (documenting findings and recommendations). Common areas tested include authentication, session management, input validation, and access controls. This methodology helps improve the security of web applications.

5. SQL Injection Methodology.

Ans: SQL Injection Methodology:

SQL Injection is a web application vulnerability that occurs when user input is not properly validated before being used in SQL queries. The testing methodology includes identifying input fields, checking for improper input validation, and determining whether database queries can be manipulated.

Security testers then verify the vulnerability in an authorized environment and assess its impact on data security. Successful SQL injection can allow unauthorized access to database information. Using parameterized queries, input validation, and prepared statements helps prevent SQL injection attacks.

6. Explain sql injection with any tool.

Ans: SQL Injection with a Tool:

SQL Injection is a vulnerability that allows attackers to manipulate database queries through improper input validation. Security professionals often use tools such as sqlmap to detect and verify SQL injection vulnerabilities during authorized security assessments. The tool automates the process of identifying vulnerable parameters and analyzing database security. It helps testers understand the impact of the vulnerability and recommend fixes. SQL injection can be prevented by using parameterized queries, prepared statements, and proper input validation.

7. Explain deference between VA And PT.

Ans: Difference Between VA and PT:

Vulnerability Assessment (VA)	Penetration Testing (PT)
VA identifies and lists security vulnerabilities in a system.	PT actively attempts to exploit vulnerabilities to determine their impact.
It focuses on finding weaknesses.	It focuses on testing how an attacker could use those weaknesses.
Mostly automated using scanning tools.	Uses both automated tools and manual testing techniques.
Provides a report of detected vulnerabilities.	Provides proof of exploitation and security risks.
Conducted regularly for security monitoring.	Conducted periodically to evaluate overall security posture.

In short: VA tells you what vulnerabilities exist, while PT shows how those vulnerabilities could be exploited and what damage they could cause.

8. How to write vulnerability assessment Report.

Ans: A Vulnerability Assessment Report is a document that describes the security weaknesses found in a system and provides recommendations to fix them.

Main Sections:

1. Executive Summary – Brief overview of the assessment and key findings.
2. Scope – Systems, networks, or applications that were tested.
3. Methodology – Tools and techniques used during the assessment.
4. Findings – List of vulnerabilities with their severity (High, Medium, Low).
5. Recommendations – Steps to remediate or reduce the identified risks.
6. Conclusion – Summary of overall security status and suggested actions.

A well-written report helps organizations understand their security risks and prioritize remediation efforts.

9.Explain the Zero Day Attacks.

Ans: Zero-Day Attack:

A Zero-Day Attack is a cyberattack that exploits a software vulnerability before the software developer becomes aware of it or releases a fix. Since no patch is available, the vulnerability is called a "zero-day" vulnerability. Attackers use these flaws to gain unauthorized access, steal data, or spread malware. Zero-day attacks are highly dangerous because users and organizations have no immediate protection against them. Regular software updates, security monitoring, and intrusion detection systems help reduce the risk of zero-day attacks.